- Allow users to use multifactor authentication (MFA) to sign in to your site.
- Prevent users from using passwords that are known to be weak or compromised, such as disallowing dictionary words, sequential characters, and so on.
- Mark authentication cookies as `http` (so that they can't be read using JavaScript) and `secure` so they'll be sent only over an HTTPS connection, never over HTTP. Where possible, you should also mark your cookies as `SameSite=strict`. See the documentation for details: http://mng.bz/a11m.
- Don't expose whether a user is already registered with your app. Leaking this information can expose you to enumeration attacks.

TIP You can learn more about website enumeration in this video tutorial by Troy Hunt: http://mng.bz/PAAA.

These guidelines represent the minimum you should be doing to protect your users. The most important thing is to be aware of potential security problems as you're building your app. Trying to bolt on security at the end is always harder than thinking about it from the start, so it's best to think about it earlier rather than later.

This chapter has been a whistle-stop tour of things to look out for. We've touched on most of the big names in security vulnerabilities, but I strongly encourage you to check out the other resources mentioned in this chapter. They provide a more exhaustive list of things to consider, complementing the defenses mentioned in this chapter. On top of that, don't forget about input validation and mass assignment/overposting, as discussed in chapter 16. ASP.NET Core includes basic protections against some of the most